IPETYM N.º 246 “DR. AMADEO SABATTINI”

FICHA DE PROYECTO E INVESTIGACIÓN TEÓRICA

Trabajo Práctico Integrador Full Stack — Entrega Semana 1

Estudiante	Elias Uriel Cortez	**Proyecto**	Kiosco La Esquina — Sistema de Gestión
Curso	7.º año “C” — Programación	**Ponderación**	30% de la nota final
Repositorio GitHub	github.com/Urielcz10/kiosco-la-esquina	**Estado**	Creado; contiene README y commit inicial.

1. FICHA DEL PROYECTO

Descripción: Mi proyecto consiste en desarrollar un sistema web para administrar las ventas y el stock de un negocio del barrio, “Kiosco La Esquina”. Busca resolver problemas comunes como controlar golosinas, bebidas y mercadería, cargar ventas diarias rápidamente y permitir que cada empleado ingrese con su propia cuenta según las tareas que tenga asignadas.

Objetivo técnico: Usar HTML y CSS para la parte visual, PHP para el backend y MySQL para guardar los datos. También aplicar medidas de seguridad, validaciones, pruebas y organización semanal mediante un tablero Kanban.

2. TABLERO PERSONAL KANBAN INICIAL

Por hacer (Backlog)	En proceso (máximo 2)	Hecho (Done)
• Diseñar las 5 tablas: Usuarios, Roles, Productos, Ventas y Detalle_Ventas. • Crear el script SQL e insertar productos de prueba. • Programar el login y la gestión de productos y ventas.	• Completar la investigación teórica de Semana 1. • Armar las pantallas iniciales de login y panel general en HTML/CSS.	• Definir nombre y alcance del kiosco. • Crear el repositorio GitHub y realizar el commit inicial. • Organizar las tareas en Kanban.

3. INVESTIGACIÓN TEÓRICA — MÓDULO I: SEGURIDAD Y ACCESOS

A. Control de Acceso Basado en Roles (RBAC)

RBAC (Role-Based Access Control) sirve para controlar qué puede ver o hacer cada usuario según el rol asignado. No alcanza con comprobar que inició sesión: también hay que verificar desde PHP qué permisos tiene. Así se evita que un empleado entre a secciones que no le corresponden. En este proyecto, los roles podrían diferenciar las tareas de administración y de venta.

B. Inyección SQL (SQLi) y consultas preparadas

La inyección SQL ocurre cuando se agregan datos ingresados por una persona directamente dentro de una consulta SQL. Alguien podría intentar alterar una consulta, saltarse el inicio de sesión o modificar información. Para prevenirlo en PHP se usan consultas preparadas, que separan la instrucción SQL de los datos recibidos:

1. **prepare()**: prepara la consulta con signos de pregunta (?) donde irán los valores.
2. **bind_param()**: vincula los valores y sus tipos a esos lugares.
3. **execute()**: ejecuta la consulta con los datos vinculados.

4. INVESTIGACIÓN TEÓRICA — MÓDULO II: ARQUITECTURA Y ENTORNO

C. Configuración de Apache mediante .htaccess

El archivo .htaccess permite configurar aspectos de Apache desde una carpeta, sin modificar la configuración global. En este proyecto se puede usar para bloquear el listado de archivos con `Options -Indexes`, restringir el acceso directo a archivos privados y definir una página personalizada para errores como el 404. Estas reglas deben probarse en el servidor donde se publique el sistema.

D. Centralización y conexión dinámica en config.php

Conviene guardar la conexión a la base de datos en un solo archivo, como config.php, e incluirlo en las páginas que la necesiten. Así no se repiten los datos y es más fácil cambiar la configuración. Se puede detectar si el sistema corre en localhost o en un servidor online para seleccionar la conexión correspondiente.

Ejemplo orientativo:

```
if ($_SERVER['HTTP_HOST'] == 'localhost') {
  $db_host = 'localhost';
  $db_user = 'root';
  $db_pass = '';
  $db_name = 'kiosco_la_esquina';
} else {
  // Completar con los datos reales del hosting
  $db_host = 'servidor_de_base_de_datos';
}
```

Así no hace falta cambiar manualmente la conexión al pasar de la computadora local al hosting. En un proyecto real, las credenciales deben mantenerse privadas y no subirse al repositorio público.

5. INVESTIGACIÓN TEÓRICA — MÓDULO III: METODOLOGÍA Y QA

E. Agilidad personal, historias de usuario y testing

Metodología y Personal Kanban: Para trabajar de forma ordenada uso un tablero con tres columnas: Por hacer, En proceso y Hecho. Muevo las tareas según su estado y limito el trabajo en proceso a dos tareas para no empezar demasiadas cosas al mismo tiempo. Esto ayuda a organizar las entregas semanales y ver qué falta completar.

Historias de usuario: Son frases cortas que describen una necesidad desde el punto de vista de quien usa el sistema. Se pueden escribir con el formato: “Como [tipo de usuario], quiero [acción], para [beneficio]”. Ejemplos para Kiosco La Esquina:

- Como empleado, quiero iniciar sesión con mi cuenta para acceder a las funciones que me corresponden.
- Como encargado, quiero registrar productos y actualizar el stock para mantener el inventario al día.
- Como vendedor, quiero cargar una venta y sus productos para registrar correctamente lo vendido.

Testing (pruebas): Consiste en probar las funciones para encontrar errores antes de entregar el sistema. Voy a comprobar que el login rechace datos incorrectos, que cada rol solo entre a sus secciones, que no se acepten cantidades o precios inválidos y que al registrar una venta se actualice el stock. También probaré campos vacíos y datos inesperados.

Criterio de calidad: Una función se considera lista cuando cumple lo pedido, muestra mensajes claros ante errores y las pruebas principales dan el resultado esperado. Los errores encontrados se corrigen y se vuelven a probar.

6. ESTADO ACTUAL Y PRÓXIMOS PASOS

El repositorio de GitHub ya está creado y tiene un README con el nombre y la descripción general del proyecto. El siguiente paso es subir la estructura de carpetas y los archivos del sistema, crear la base de datos con sus cinco tablas y avanzar con las pantallas iniciales. Después se implementarán los permisos, las consultas preparadas y las pruebas.

Repositorio: https://github.com/Urielcz10/kiosco-la-esquina

Elias Uriel Cortez — Kiosco La Esquina